

SecureOrg Inc.

PCI DSS Compliance Framework

Information Security Policy

Document Reference:

ISP-001

Version:

2.1

Effective Date:

April 14, 2026

Document Owner:

Chief Information Security Officer

Classification:

CONFIDENTIAL

Review Cycle:

Annual

Framework:

PCI DSS v4.0

This document contains confidential and proprietary information. Unauthorized disclosure is prohibited.

Table of Contents

1. Purpose and Scope
2. Policy Statement
3. Roles and Responsibilities
4. Information Security Principles
5. PCI DSS Alignment
6. Asset Management
7. Risk Management
8. Compliance and Enforcement
9. Policy Review and Maintenance
10. Revision History

1. Purpose and Scope

1.1 Purpose

This Information Security Policy ("Policy") establishes the strategic framework for protecting SecureOrg Inc.'s information assets, systems, and data, with particular emphasis on cardholder data (CHD) and sensitive authentication data (SAD) in accordance with the Payment Card Industry Data Security Standard (PCI DSS) version 4.0.

This Policy defines the minimum baseline of security controls, responsibilities, and behaviors required of all individuals who access company systems and data. It provides the foundation upon which all subordinate security policies, standards, and procedures are built.

1.2 Scope

This Policy applies to:

- All employees, contractors, consultants, temporary workers, and third parties who access SecureOrg Inc. systems, networks, or data
- All information systems, applications, and infrastructure owned, operated, or managed by SecureOrg Inc.
- All locations and environments where cardholder data is stored, processed, or transmitted
- All cloud environments, hosted services, and outsourced processing that handle payment card data
- All business processes that interact with the cardholder data environment (CDE)

1.3 Definitions

Cardholder Data (CHD): Any information printed, processed, transmitted, or stored on a payment card including the Primary Account Number (PAN), cardholder name, expiration date, and service code.

Sensitive Authentication Data (SAD): Security-related information used to authenticate cardholders and/or authorize payment card transactions, including full track data, card verification codes/values, and PINs.

Cardholder Data Environment (CDE): The people, processes, and technology that store, process, or transmit cardholder data or sensitive authentication data, including any connected system components.

Information Asset: Any data, system, hardware, software, or intellectual property that has value to the organization and requires protection.

2. Policy Statement

2.1 Overarching Security Commitment

SecureOrg Inc. is committed to maintaining the confidentiality, integrity, and availability (CIA triad) of all information assets, particularly those related to payment card processing. The organization shall establish, implement, maintain, and continuously improve an Information Security Management System (ISMS) that meets or exceeds the requirements of PCI DSS v4.0.

2.2 Core Security Principles

The organization operates under the following foundational security principles:

- **Confidentiality:** Information shall only be accessible to authorized individuals and systems on a need-to-know basis. Cardholder data shall be protected from unauthorized disclosure at all times.
- **Integrity:** The accuracy and completeness of information and processing methods shall be safeguarded. Unauthorized alteration of data shall be detected and prevented.
- **Availability:** Authorized users shall have reliable access to information and systems when required to perform legitimate business functions.
- **Accountability:** All actions affecting information security shall be traceable to individual users or system accounts to ensure non-repudiation.
- **Defense-in-Depth:** Multiple layers of security controls shall be implemented to protect against threats, ensuring no single point of failure compromises security.
- **Least Privilege:** Access rights shall be restricted to the minimum necessary for users and systems to perform their authorized functions.
- **Separation of Duties:** Critical functions shall be divided among multiple individuals to prevent fraud and errors.

2.3 Zero Tolerance

The organization maintains a zero-tolerance position on unauthorized access to, disclosure of, or modification of cardholder data. Any confirmed breach of this Policy shall be subject to disciplinary action up to and including termination of employment or contract, and may result in civil or criminal prosecution.

3. Roles and Responsibilities

3.1 Governance Structure

Effective information security requires clearly defined responsibilities at every level of the organization. The following structure governs security oversight:

3.2 Board of Directors / Executive Leadership

- Approve and champion the organization's information security strategy
- Ensure adequate resources are allocated to information security programs
- Receive quarterly security posture reports from the CISO
- Oversee PCI DSS compliance program at the executive level

3.3 Chief Information Security Officer (CISO)

- Own this Policy and all subordinate security policies and standards
- Develop, implement, and maintain the organization's security program
- Serve as the primary liaison with payment card brands and acquiring banks
- Manage relationships with Qualified Security Assessors (QSA)
- Report security incidents to executive leadership and the board as required
- Oversee the annual PCI DSS assessment process

3.4 Information Security Team

- Implement and operate security controls across all systems and environments
- Monitor security events and investigate potential incidents
- Conduct vulnerability assessments and penetration testing
- Maintain security documentation and evidence for PCI DSS compliance
- Provide security awareness training to all staff

3.5 System Owners and Administrators

- Ensure systems under their management comply with this Policy and relevant standards
- Implement technical controls as specified by the Information Security team
- Report security vulnerabilities and incidents promptly

- Maintain system configurations in accordance with approved hardening standards

3.6 All Employees and Contractors

- Comply with all provisions of this Policy and related security documents
- Complete mandatory security awareness training annually and upon hire
- Report suspected security incidents to the Information Security team immediately
- Protect credentials and access tokens from unauthorized disclosure
- Not attempt to circumvent security controls or access unauthorized data

4. Information Security Principles

4.1 Information Classification

All information assets must be classified according to their sensitivity and the risk their compromise would pose to the organization or its customers:

RESTRICTED

Most sensitive data requiring maximum protection

PAN, SAD, cryptographic keys

Encrypt at rest and in transit; strict need-to-know

CONFIDENTIAL

Sensitive business data with limited distribution

Customer PII, audit logs, security configs

Encrypt in transit; role-based access

INTERNAL

General business information for internal use

Internal procedures, employee data

Access controls; no external sharing without approval

PUBLIC

Information approved for public release

Marketing materials, public website content

No special handling required

4.2 Data Minimization

The organization shall collect, process, and retain only the minimum cardholder data necessary to fulfil legitimate business requirements. Specifically:

- Full PAN shall be masked when displayed, showing at most the first six and last four digits
- SAD shall never be stored after authorization, even if encrypted
- CHD retention periods shall be documented and data securely deleted upon expiration
- Quarterly processes shall scan for and remove any stored SAD or unneeded CHD

4.3 Cryptographic Controls

Strong cryptography shall be used to protect CHD and other sensitive data:

- All CHD in transit shall use TLS 1.2 or higher; TLS 1.0 and 1.1 are prohibited
- CHD at rest shall be encrypted using AES-256 or equivalent approved algorithms

- Cryptographic key management shall follow documented procedures per PCI DSS Requirement 3
- Cryptographic keys shall be rotated at least annually and upon personnel changes

5. PCI DSS Alignment

5.1 PCI DSS Framework Overview

This Policy directly supports compliance with all 12 PCI DSS requirements. The following matrix maps key Policy provisions to PCI DSS requirements:

Req 1: Network Security
Install and maintain network security controls
Section 4.3, Subordinate Policy NSP-001
Req 2: Secure Configurations
Apply secure configurations to all system components
Section 4.2, Subordinate Policy SCP-001
Req 3: Protect Stored Data
Protect stored account data
Section 4.2, 4.3
Req 4: Protect Data in Transit
Protect cardholder data with strong cryptography during transmission
Section 4.3
Req 5: Anti-Malware
Protect all systems against malware
Section 4.1
Req 6: Secure Development
Develop and maintain secure systems and software
Subordinate Policy SDP-001
Req 7: Restrict Access
Restrict access to system components and cardholder data
Section 4.1, Subordinate Policy ACP-001
Req 8: Identify Users
Identify users and authenticate access
Subordinate Policy PWP-001
Req 9: Physical Security
Restrict physical access to cardholder data
Subordinate Policy PSP-001
Req 10: Logging
Log and monitor all access to system components and cardholder data
Section 4.1
Req 11: Test Security
Test security of systems and networks regularly
Subordinate Policy VAP-001
Req 12: Security Policy
Support information security with organizational policies
This Policy

5.2 Customized Approach

Where the organization elects to use the customized approach for specific PCI DSS requirements, compensating controls or alternative security objectives shall be documented, approved by the CISO, and submitted to the QSA for review. All customized approach implementations shall be tested annually.

6. Asset Management

6.1 Asset Inventory

The organization shall maintain a comprehensive, up-to-date inventory of all system components within the cardholder data environment and connected systems. This inventory shall include:

- Hardware: servers, network devices, terminals, end-user devices
- Software: operating systems, applications, and utilities
- Virtual and cloud components: VMs, containers, cloud services
- Data flows: documentation of all CHD flows between systems

The asset inventory shall be reviewed and verified quarterly to ensure accuracy. Any undocumented or unauthorized components discovered shall be investigated as potential security incidents.

6.2 Asset Lifecycle Management

Security controls shall be applied throughout the entire lifecycle of information assets:

- Procurement: Security requirements shall be specified and evaluated during the procurement process
- Deployment: Assets shall be configured according to approved hardening standards before deployment to production
- Operation: Assets shall be maintained, patched, and monitored throughout their operational life
- Retirement: Assets shall be securely decommissioned, with all sensitive data cryptographically erased or physically destroyed

6.3 Third-Party and Service Provider Management

Third parties with access to the CDE or CHD shall be subject to formal risk assessments and contractual security requirements, including:

- Documented security responsibilities in contracts or service agreements
- Provision of PCI DSS compliance status (AOC or equivalent) annually
- Right-to-audit clauses for security assessment purposes
- Incident notification obligations within 24 hours of discovery

7. Risk Management

7.1 Risk Assessment Program

The organization shall maintain a formal risk management program to identify, analyze, evaluate, and treat information security risks. Risk assessments shall be conducted:

- Annually as part of the PCI DSS compliance cycle
- Following significant changes to the CDE or business operations
- After any confirmed security incident affecting CHD
- When threat intelligence indicates new or emerging risks

7.2 Risk Treatment

Identified risks shall be treated through one or more of the following approaches:

- Risk Acceptance: Residual risks within the organization's defined risk tolerance may be formally accepted by the CISO or executive leadership with documented justification
- Risk Mitigation: Technical or administrative controls shall be implemented to reduce the likelihood or impact of identified risks
- Risk Transfer: Risks may be transferred through contractual agreements, insurance, or outsourcing where appropriate
- Risk Avoidance: Business activities or processes that introduce unacceptable risks may be discontinued or redesigned

7.3 Threat Intelligence

The organization shall maintain awareness of the current threat landscape through:

- Subscription to payment industry threat intelligence feeds
- Participation in Information Sharing and Analysis Organizations (ISACs)
- Regular review of CERT advisories and vendor security bulletins
- Engagement with the PCI SSC and payment brand security programs

8. Compliance and Enforcement

8.1 Compliance Monitoring

Compliance with this Policy shall be monitored through:

- Annual PCI DSS assessments conducted by a qualified QSA
- Internal security audits conducted quarterly
- Automated configuration compliance scanning
- Security awareness training completion tracking
- Incident and exception reporting mechanisms

8.2 Policy Exceptions

Exceptions to this Policy shall only be granted through the formal exception management process:

- Requestor documents the business justification and risk assessment for the exception
- The Information Security team reviews and provides a security impact assessment
- The CISO approves or denies the exception in writing
- Approved exceptions are time-limited (maximum 90 days unless otherwise approved) and tracked in the exception register
- All active exceptions are reviewed quarterly; expired exceptions without renewal result in mandatory remediation

8.3 Enforcement and Disciplinary Action

Violations of this Policy shall be subject to disciplinary action commensurate with the severity of the violation, applicable law, and the employment or contractual relationship:

- Minor violations: Documented warning and mandatory retraining
- Moderate violations: Formal written warning and increased monitoring
- Serious violations: Suspension pending investigation, potential termination
- Criminal violations: Immediate suspension, termination, and referral to law enforcement

8.4 Legal and Regulatory Compliance

This Policy operates within the context of applicable laws and regulations including, but not limited to, GDPR, CCPA, PCI DSS, and applicable financial regulations. Where legal requirements are more stringent than this Policy, the legal requirements shall prevail.

9. Policy Review and Maintenance

9.1 Review Schedule

This Policy shall be formally reviewed at minimum annually and whenever any of the following occur:

- Updates to PCI DSS requirements that impact Policy provisions
- Significant changes to the organization's operating environment
- Material security incidents that reveal gaps in the Policy
- Changes in applicable laws or regulatory requirements
- Mergers, acquisitions, or significant business structure changes

9.2 Review Process

The annual review shall include participation from:

- Chief Information Security Officer (Policy Owner)
- Chief Technology Officer or equivalent
- Legal and Compliance department
- Key business unit leaders with CDE involvement
- Internal Audit

9.3 Communication

All updates to this Policy shall be communicated to affected personnel within 30 days of approval. Updates requiring immediate action shall be communicated within 24 hours. All personnel shall acknowledge receipt and understanding of the current Policy version as part of the annual security awareness process.

10. Revision History

1.0

Jan 15, 2024

Initial release

CISO Office

1.1

Jul 10, 2024

Updated PCI DSS v4.0 alignment; added customized approach section

Security Team

2.0

Jan 12, 2025

Major revision: expanded asset management; updated roles

CISO Office

2.1

Apr 14, 2026

Annual review; updated threat intelligence section; regulatory updates

CISO Office

Document Approval

Chief Information Security Officer

April 14, 2026

Chief Executive Officer

April 14, 2026

Chief Technology Officer

April 14, 2026